

OXHUNTER — Security Scan Report

Target: <http://google.com> | Date: | OXHUNTER v2.x

Vulnerability Summary

CRITICAL	0
HIGH	2
MEDIUM	4
LOW	2
INFO	1

Detailed Findings

#1 CSRF [HIGH]

URL	http://google.com
Evidence	POST form submits to external domain https://services.google.com/fb/submissions/googleaccessibilitynewsletter/ without CSRF protection
Fix	Remove cross-origin form submissions. If necessary, implement strict CORS and CSRF protection.

#2 Security Header [MEDIUM]

URL	http://google.com
Evidence	Missing header: Strict-Transport-Security - HSTS - Forces HTTPS connections
Fix	Add: Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

#3 Security Header [MEDIUM]

URL	http://google.com
Evidence	Missing header: X-Content-Type-Options - Prevents MIME-type sniffing
Fix	Add: X-Content-Type-Options: nosniff

#4 Security Header [HIGH]

URL	http://google.com
Evidence	Missing header: Content-Security-Policy - XSS and data injection protection
Fix	Add a strict Content-Security-Policy header. Start with: default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'

#5 Security Header [LOW]

URL	http://google.com
Evidence	Missing header: Referrer-Policy - Controls referrer information leakage
Fix	Add: Referrer-Policy: strict-origin-when-cross-origin or no-referrer

#6 Security Header [LOW]

URL	http://google.com
Evidence	Missing header: Permissions-Policy - Controls browser features/APIs
Fix	Add: Permissions-Policy: geolocation=(), microphone=(), camera=()

#7 Security Header [INFO]

URL	http://google.com
Evidence	Information disclosure: Server: gws
Fix	Configure server to suppress or genericize Server header

#8 SSL/TLS [MEDIUM]

URL	
Evidence	Strict-Transport-Security (HSTS) header is missing
Fix	Add HSTS header: Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

#9 SSL/TLS [MEDIUM]

URL	
Evidence	HTTP redirects to non-HTTPS location: http://www.google.com/
Fix	Ensure HTTP redirects go to HTTPS URL.

